

Cisco Secure Workload - BSI C5 Compliance Report

Cisco Secure Workload - BSI C5 Compliance Report

Customer-Facing Compliance Report

Framework: BSI Cloud Computing Compliance Criteria Catalogue (C5:2020)

Primary audience: Cloud service providers (CSPs) and cloud-hosted workload owners serving German federal / public-sector customers or any customer that contractually requires C5 evidence.

CSW positioning: Cloud workload segmentation, operations security (OPS), communication security (KOS), workload-to-workload identity and access management (IDM), asset management (AM), and security incident management (SIM) evidence.

Framework Version Note

References C5:2020. BSI may publish revisions; validate the catalogue version against the customer's assessment scope. C5 distinguishes Basic Criteria from Additional Criteria (the latter expanding evidence requirements). Topic areas in this report are referenced by name and area abbreviation; specific criterion numbering may vary across catalogue revisions.

CSW UI Navigation Note

Cisco does not yet publish framework-specific CSW UI navigation for this standard; framework-specific navigation is on the product roadmap. This report references CSW *capabilities* and the *evidence artifacts* they produce. The technical runbook (CSW-BSI-C5-Technical-Runbook.md) in this folder contains the deeper engineering detail.

How to read the Coverage column

Every report in this set uses the same three coverage words. Coverage describes **what evidence CSW produces** for a topic — it never means the control is passed.

Direct — Secure Workload produces the primary evidence artifact for that topic (segmentation, policy, flow/process telemetry, inventory, vulnerability + reachability, forensic reconstruction). Direct is still evidence, not an attestation.

Supporting — Secure Workload contributes an input that feeds or complements another control, tool, or process (e.g. detection input only, reconciled against an external register, one log source among several).

Evidence Required — Secure Workload has no record for this topic. The customer supplies the contract, the analysis, or the HR / physical-security evidence from another control.

The Coverage ratings in the topic map below are machine-derived from each row's wording and are flagged for SE review before customer use.

Executive Summary

Cisco Secure Workload (CSW) supports a defined subset of this framework. The strongest customer story is not that CSW “certifies” compliance; it is that CSW turns workload communication and inventory into evidence that the customer, the customer’s compliance team, and the customer’s assessor can review. This report describes which framework topics CSW supports, which it does not, what evidence artifacts CSW produces, and how often the customer should collect them. CSW does **not** replace the customer’s governance, policy, or assessor judgement, and this report is **not** a control attestation.

Suggested CSW Scope Pattern

BSI - C5

- └ Customer-Tenants (Tenant-A, Tenant-B, Tenant-C ...)
- └ Shared-Infrastructure (Identity-Layer, Logging-Telemetry, Patch-Configuration, Backup-Layer)
- └ Management-Plane (Operator-Jump-Hosts, Admin-Consoles)
- └ External-Service-Providers

This scope pattern should be validated with the customer’s architecture, application owners, compliance team, and assessor before it is used for formal evidence.

In Scope for CSW Evidence

- Asset Management (AM)
- Communication Security (KOS) - tenant separation and segmentation
- Operations Security (OPS) - monitoring, vulnerability + reachability, configuration baseline
- Identity and Access Management (IDM) - workload-to-workload layer
- Cryptography (KRY) - plaintext-flow detection only
- Supplier / Sub-Service Provider Control (SP)
- Security Incident Management (SIM)
- Business Continuity (BCM) - approved flow baseline as input to recoverability
- Compliance (COM) and Investigation (INQ) - evidence pack inputs

Out of Scope (Must Be Evidenced by Other Controls / Tools / Processes)

- Organisation of Information Security (OIS)
- Personnel (HR)
- Physical Security (PS)
- Portability and Interoperability (PI)

- Procurement, Development, and Modification (DEV) - code-level controls
- Cryptography enforcement and key management (KRY enforcement)

Framework Topic → CSW Capability Map

Framework topic	Coverage	CSW capability	Evidence artifact
Asset Management (AM)	Direct	Workload inventory; scope + label export	Inventory + classification evidence
Communication Security (KOS) - tenant separation	Direct	Policy workspace + cross-tenant deny enforcement	Workspace snapshot + cross-tenant violation log (the heart of multi-tenant KOS evidence)
Operations Security (OPS)	Direct	Continuous monitoring; vulnerability + reachability; configuration drift on policy	Operations evidence pack
Identity and Access Management (IDM)	Direct	Policy workspace + enforcement / violation log	Workload-to-workload privilege evidence
Cryptography (KRY) - detection	Supporting	Plaintext-flow detection on regulated paths	Detection input only
Sub-Service Provider Control (SP)	Direct	Outbound flow summary to service-provider endpoints	Service-provider egress report
Security Incident Management (SIM)	Direct	Forensic flow + process telemetry	Investigation pack with timeline and tenant-impact scope
Business Continuity (BCM)	Supporting	Approved flow baseline	Recoverability input only
Compliance (COM)	Direct	Periodic evidence pack	Auditor work-paper input

Evidence Collection Approach

The table below describes per-topic evidence collection - what to collect, the CSW source area, and a suggested cadence. The cadence should be tuned to the customer's audit cycle, regulatory cadence, and risk appetite.

Topic	What to collect	CSW source	Suggested cadence
Cloud workload inventory across tenants	Workloads grouped by tenant and service offering	Inventory + scope membership export filtered by tenant, customer, service_offering	Monthly
Tenant separation evidence	Cross-tenant deny enforcement and violation log	Policy workspace export + policy analysis output	Continuous; reviewed quarterly
Operations evidence	Continuous monitoring + reachability-weighted vulnerability data	Vulnerability report scoped to BSI-C5 + alert log	Monthly
Sub-service-provider egress	Outbound flow to External-Service-Providers	Flow search filtered to external service-provider endpoints	Monthly
Incident sample (per tenant)	Workload-level timeline including tenant identification	Flow + process search	Per incident; one representative sample per audit cycle

POV / Workshop Approach

1. Confirm the framework version and assessment cycle with the customer's compliance team.
2. Select one business service, regulated boundary, or critical workload group to start with; do not attempt to instrument the entire estate in the POV.
3. Validate workload coverage and install sensors or configure supported connectors. Document the cannot-instrument register; this is itself evidence.
4. Apply labels for application, environment, owner, data class, criticality, compliance scope, and any framework-specific tags (e.g. tenant, prototype, isa_level, npi, cui, ephi).
5. Observe flows over a representative business window. Minimum two weeks; longer if the customer has month-end, quarterly, or seasonal cycles relevant to the scope.
6. Use ADM to generate a candidate policy. Review with the application owner. Run in Simulation mode for at least two weeks before any enforcement.
7. Package inventory, scope, flows, policy, exceptions, and known gaps as the evidence output. Cross-reference this report's evidence collection table with the customer's existing audit work-papers.

Boundaries and Complementary Controls

CSW does not replace BSI C5 attestation, CSP organisational and physical controls, supplier contractual arrangements, identity lifecycle, key management / cryptography enforcement, backup/DR, portability and interoperability assurance, or shared-responsibility model decisions.

Assessor / Auditor Caveat

CSW provides technical evidence inputs. The customer's qualified assessor, auditor, certifying body, or regulator determines compliance status. Validate all framework-topic mappings, control IDs, paragraph references, and section numbers in this report against the current official framework text. If the customer is being assessed against a version other than the one referenced in the framework version note above, revalidate before use.

Disclaimer

This report is for informational and planning purposes. It is not legal, regulatory, audit, or certification advice. Validate all mappings against the current official framework text, the customer's environment, and qualified compliance, legal, and audit professionals.